3. ANALISI DELLA TECNICA DI EVASIONE:

Ci sono state diverse fasi:

1 Manipolazione del File (Bypassing DLP)

Il dipendente, consapevole che il gateway DLP blocca i file con header binari (PDF), ha utilizzato PowerShell per neutralizzare la firma del file.

Codifica: Ha letto il file PDF come array di byte e lo ha convertito in una stringa **Base64.**

2 Mascheramento: Ha salvato la stringa risultante in un file rinominato debug_dump_x86.log. Poiché il contenuto era ora puramente testuale e l'estensione .log è solitamente consentita per i log di debug degli sviluppatori, inquesto modo il gateway non ha rilevato l'anomalia.

3 Metodo di Esfiltrazione

L'attribuzione è certa grazie ai log di rete e al transcript di PowerShell. Marco V. ha utilizzato il comando Invoke-RestMethod per effettuare una chiamata API verso **GitHub**.
Destinazione: https://api.github.com/gists
Identificativo: Gist creato sotto l'account MarcoV_Dev.
Vettore: Traffico HTTPS criptato, che ha permesso di superare l'ispezione dei contenuti del gateway poiché diretto verso un dominio di sviluppo (GitHub) considerato "sicuro" dalla policy aziendale.

4. Tentativi di occultamento

L'indagato ha messo in atto diverse strategie per eliminare le prove:

Cancellazione Sicura: Ha utilizzato il comando Remove-Item -Force per eliminare il file temporaneo utilizzato per l'esfiltrazione.

Cancellazione Log: Ha eseguito il comando wevtutil cl "Windows PowerShell" per pulire la cronologia degli eventi PowerShell.

Tentativo Fallito: Ha cercato di cancellare i log di **Security** (wevtutil cl "Security"), ma l'operazione è stata negata dal sistema per mancanza di privilegi amministrativi.

Attributi Nascosti: Il file temporaneo era stato inizialmente creato con l'attributo Hidden per sfuggire a controlli superficiali.

5. Azioni Correttive

Per evitare il ripetersi di simili incidenti, si raccomandano le seguenti contromisure:

1° **Ispezione SSL/TLS (MIM):** Implementare l'ispezione del traffico cifrato anche verso siti "trusted" come GitHub per rilevare l'invio di stringhe Base64 ad alto volume.

2° **Limitazione PowerShell:** Restringere l'uso di PowerShell tramite *Constrained Language Mode* o bloccare l'esecuzione di script non firmati per gli utenti, inclusi gli sviluppatori, limitando l'uso di Invoke-RestMethod.

3° **Monitoraggio Anomalie di Volume:** Implementare alert per l'upload di file di testo (.log, .txt) che superano dimensioni insolite (es. > 1MB) verso destinazioni esterne.

4° **Endpoint Detection & Response (EDR):** Configurare l'EDR per segnalare immediatamente comandi di pulizia log come wevtutil cl.